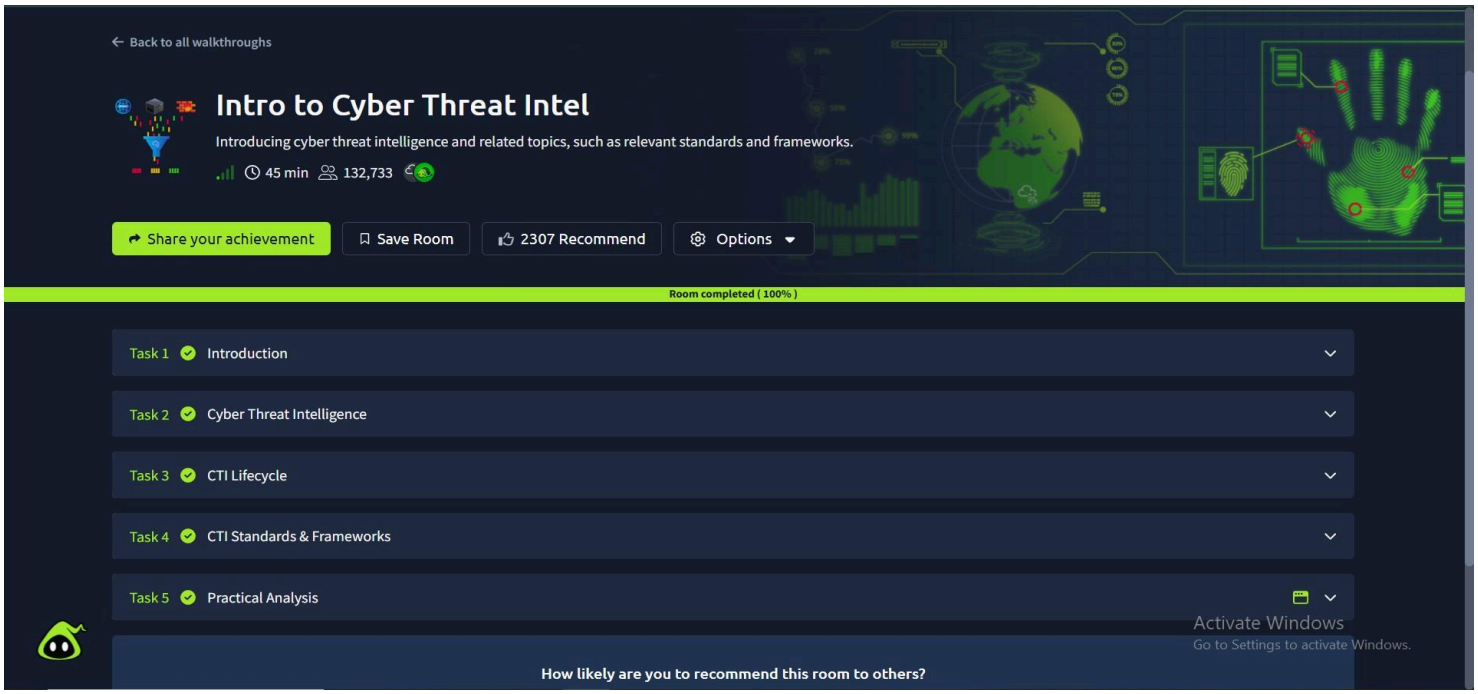
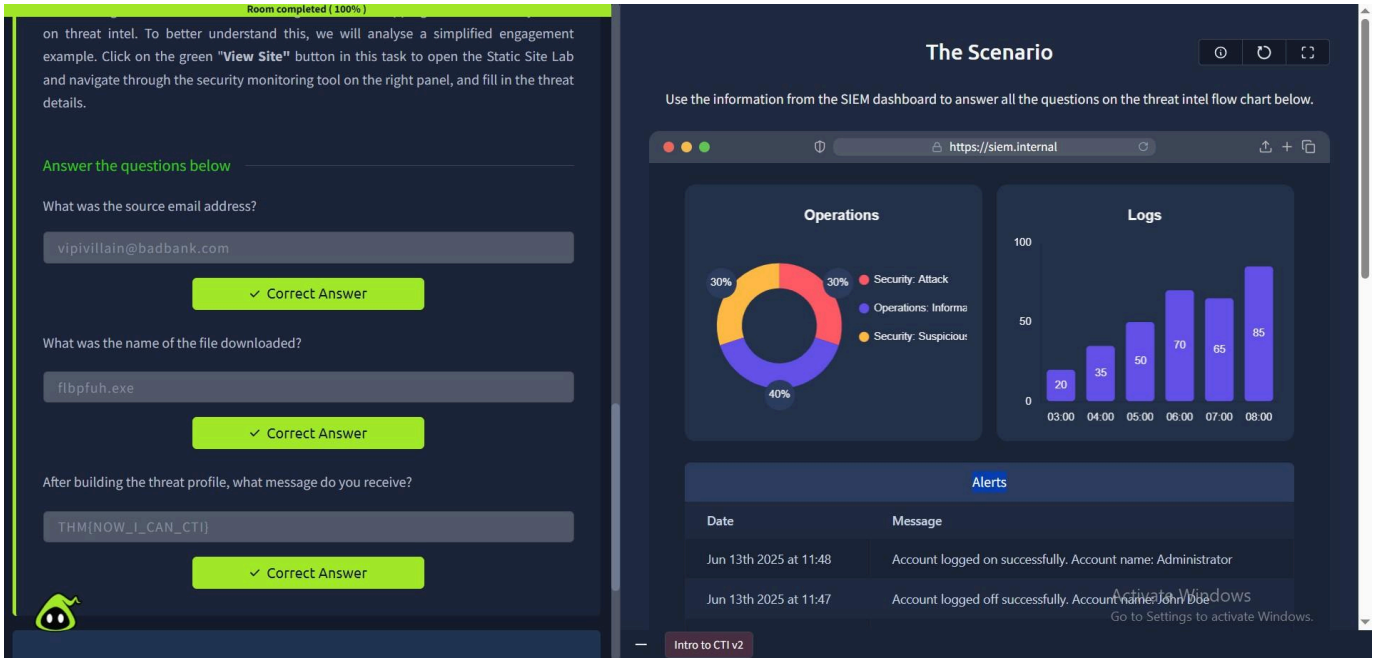
Phishing Attack Leading to Endpoint Compromise – SOC Investigation Report



Incident Summary **:**

A phishing email was received by a user (John Doe), which led to the download and execution of a malicious file. Subsequent activity indicates possible system compromise and unauthorized access. This investigation simulates a real-world SOC scenario involving phishing-induced endpoint compromise.



TIMELINES OF EVENTS : -

Jun 12, 08:40 – Email received from vipivillain@badbank.com

Jun 12, 08:41 – Malicious file (flbpfuh.exe) downloaded

Jun 12, 08:42 – Registry modified (possible persistence)

Jun 12, 16:34 – Outbound connection to 91.185.23.222

Jun 13, 11:47 – User John Doe logged off

Jun 13, 11:48 – Administrator account logged in

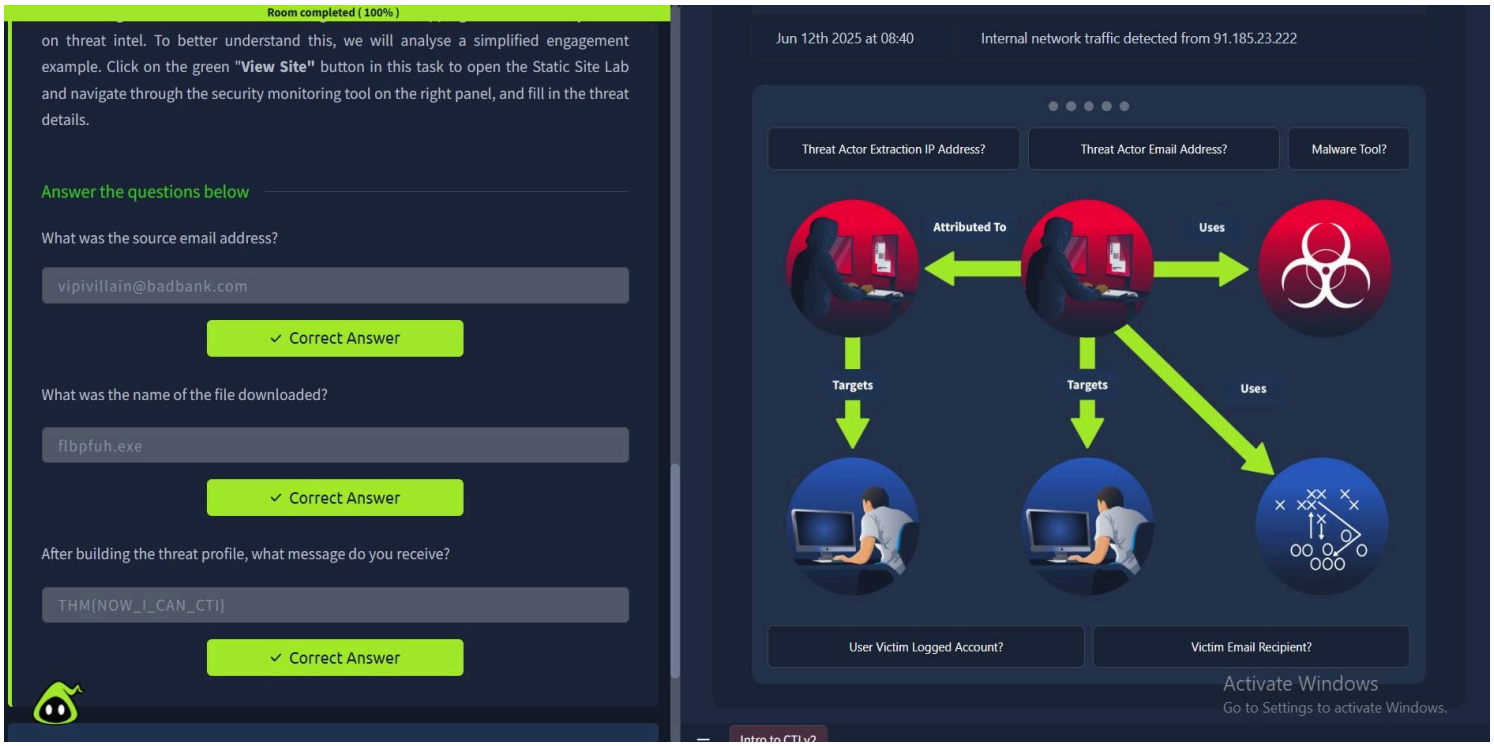
Brief Analysis : -

- The email exhibits characteristics of a phishing attempt, including a suspicious sender domain.
- The user executed a malicious attachment, initiating system compromise.
- Registry modification indicates persistence mechanisms were established.
- Outbound communication to an external IP suggests command-and-control activity.
- The use of the Administrator account indicates possible privilege escalation or account compromise.

Indicators of Compromise (IOCs):

- Email: vipivillain@badbank.com
- File: flbpfuh.exe
- IP: 91.185.23.222

Attack Classification : - This attack involves phishing (initial access), malware execution, and possible lateral movement or privilege escalation.



Impact Assessment : -

The compromise of the endpoint could allow an attacker to maintain persistent access, exfiltrate sensitive data, and escalate privileges within the network.

MITRE ATT&CK Mapping : - The observed attack aligns with the following MITRE ATT&CK techniques:

T1566 – Phishing

T1204 – User Execution

T1547 – Persistence

T1105 – C2 Communication

T1078 – Valid Accounts

RECOMMENDATIONS : - To mitigate the impact of this incident and prevent future occurrences, the following actions are recommended:

- Block Malicious Indicators:
  Immediately block the identified IP address (`91.185.23.222`) and suspicious email/domain to prevent further communication.
- Isolate Affected System:
  Disconnect the compromised machine from the network to stop potential lateral movement.
- Credential Reset:
  Reset passwords for the affected user account and any privileged accounts, especially the Administrator account.
- Perform Malware Scan and Removal:
  Conduct a full system scan to detect and remove any malicious files or persistence mechanisms.
- User Awareness Training:
  Educate users on identifying phishing emails to reduce the likelihood of similar attacks.